Rochester Security Summit

Hacking and Defending XIoT

A hardware hacker and OT security expert share their perspectives on building, breaking and defending XIoT devices.

Introductions

Zack Lehmann

- Senior Consultant
- ~5 years at SRA
- Monitoring & Detection in CPS/OT/XIoT

Gabe Siftar

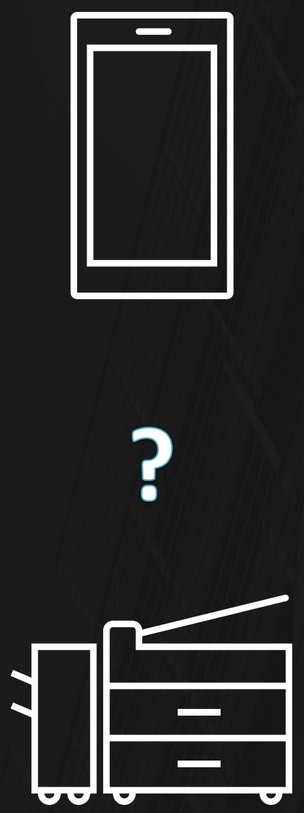
- Lead Scientist
- 5 years at SRA
- 20 years as design engineer for medical device manufacturer
- Offensive Security with focus on XIoT, OT/ICS, hardware devices

SecurityRisk ADVISORS

Agenda

- Intro to XIoT
- Attacking XIoT
- Securing XIoT
- Q&A

XIoT



XIoT Defined

XIoT Devices:

- Network-connected
- Interacts with the world (sensors, actuators, etc)
- Single-function
- “Security-Challenged”
- Runs firmware

Rule of thumb: If it runs EDR, it’s probably *not* XIoT.

XIoT – “Extended Internet of Things”

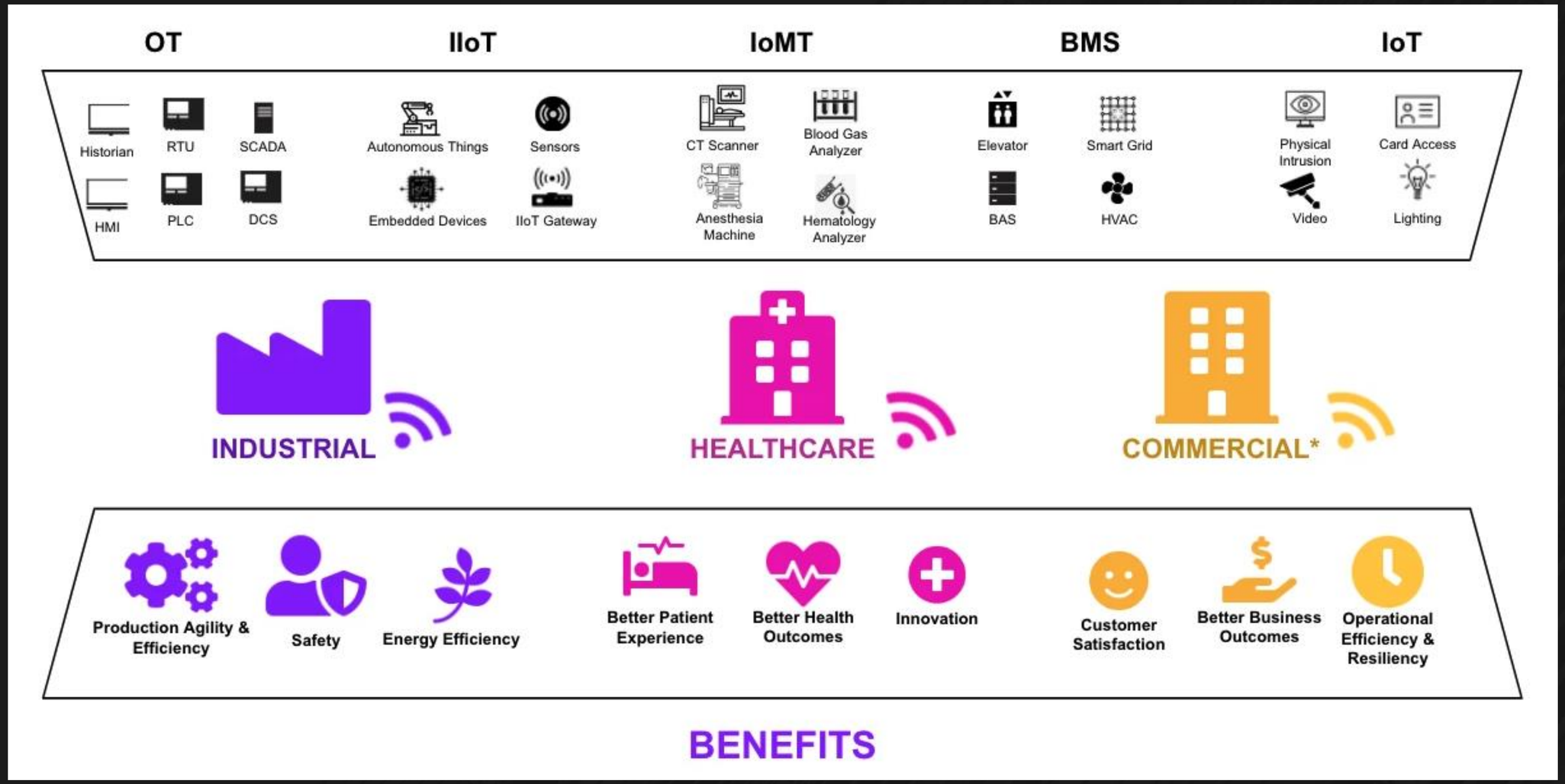
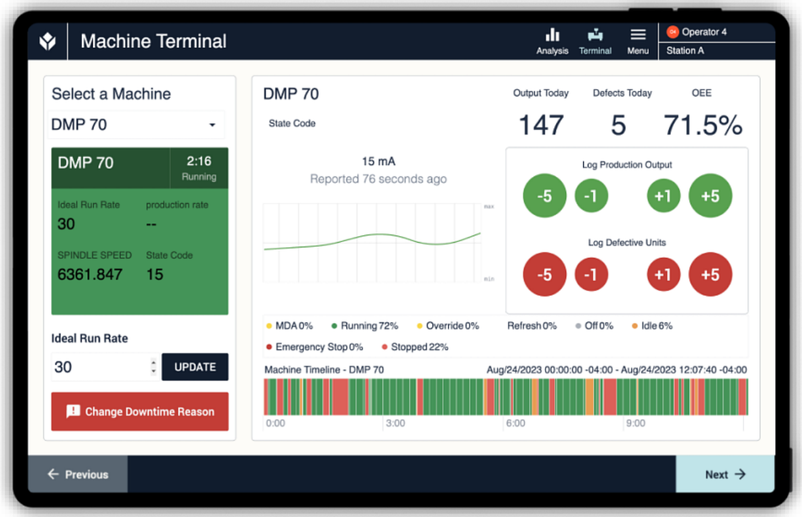


Image source: https://claroty.com/blog/extended-internet-of-things-xiot-faq

Product Example

Industrial Internet of Things (IIoT)



- Installed in settings such as water treatment or manufacturing facilities to provide:
  - Remote collection of operational data
  - Control of machine parameters
  - Extend existing input (sensing) or output capabilities
  - Enterprise integrations (ERP/MES)
  - Cloud integration capabilities to other IIoT devices with API's (e.g. digital scale)

Device: Tulip Edge IO https://tulip.co/products/edge-io/

XIoT – Why Care?

- Increasingly deployed
- Increasing dependency
- Devices hide in the shadows
- Immature tools and practices
- Vulnerabilities frequently identified, ex:
  - Akuvox E11 smart intercom – Claroty's Team82 discovered 13 vulnerabilities
- Increasingly interesting to potential attackers, ex:
  - QUIETEXIT Attack – compromised SSH client commonly found on embedded devices. Attributed to APT29

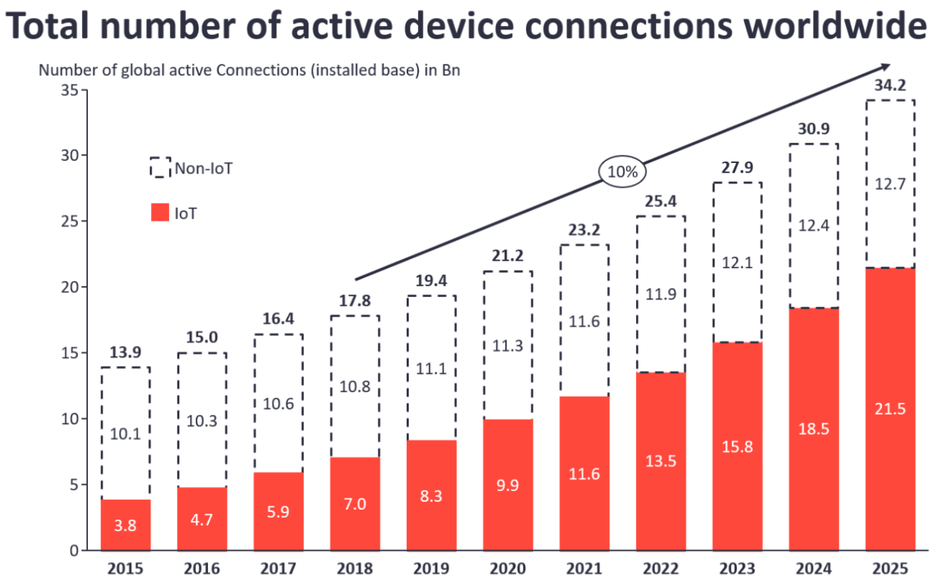


Image Source: https://iot-analytics.com/wp/wp-content/uploads/2018/08/Number-of-global-device-connections-2015-2025-Number-of-IoT-Devices.png

XIoT Security Threats & Weaknesses

Inherent

Introduced by Manufacturers

- Weak product security
- Slow patch/update cycles
- Insecure default configurations
- Straight-up vulnerabilities (proprietary code or 3rd–party components)

packet storm
exploit the possibilities
Home | Files | News | About | Contact

Hikvision IP Camera Unauthenticated Command Injection

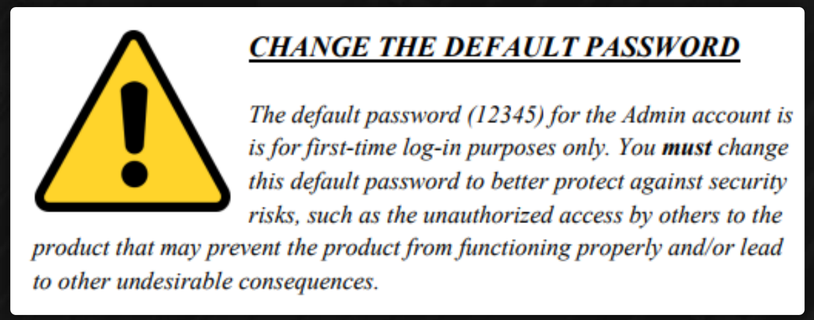
Authored by bashis, jbaines-r7, Watchful_IP | Site metasploit.com — Posted Feb 28, 2022

This Metasploit module exploits an unauthenticated command injection in a variety of Hikvision IP cameras (CVE-2021-36260). The module inserts a command into an XML payload used with an HTTP PUT request sent to the /SDK/webLanguage endpoint, resulting in command execution as the root user. This module specifically attempts to exploit the blind variant of the attack. The module was successfully tested against an HWI-B120-D/W using firmware V5.5.101 build 200408. It was also tested against an unaffected DS-2CD2142FWD-I using firmware V5.5.0 build 170725. Please see the Hikvision advisory for a full list of affected products.

Deployment-Based

Introduced by End-Users

- Deployed on enterprise segments
- Insecure default configuration
  - Default passwords
  - Unused features enabled
- Security features not enabled/correctly configured
- Patches & updates not applied


CHANGE THE DEFAULT PASSWORD

*The default password (12345) for the Admin account is is for first-time log-in purposes only. You **must** change this default password to better protect against security risks, such as the unauthorized access by others to the product that may prevent the product from functioning properly and/or lead to other undesirable consequences.*

https://us.hikvision.com/en/system/files_force/manual/20150119024136900.pdf

Attacking XIoT

Hacking Example

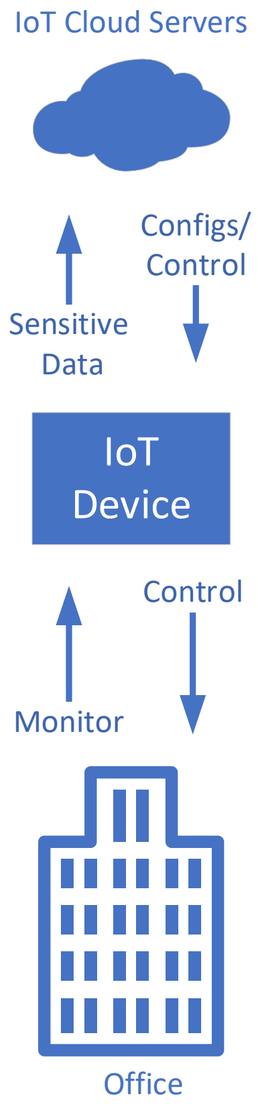
Device Tested: [Redacted due to pending responsible disclosure process]

Device Characteristics:

- Commonly found in enterprise and commercial settings
- Stores and transfers sensitive data
- Interfaces with the physical environment
- Communicates with cloud-based systems

Attack Objectives:

- Access to Sensitive Data (local and cloud)
- Denial of Service
- Manipulation of Control



Hacking Example - Findings

Vulnerability : Local access to sensitive data

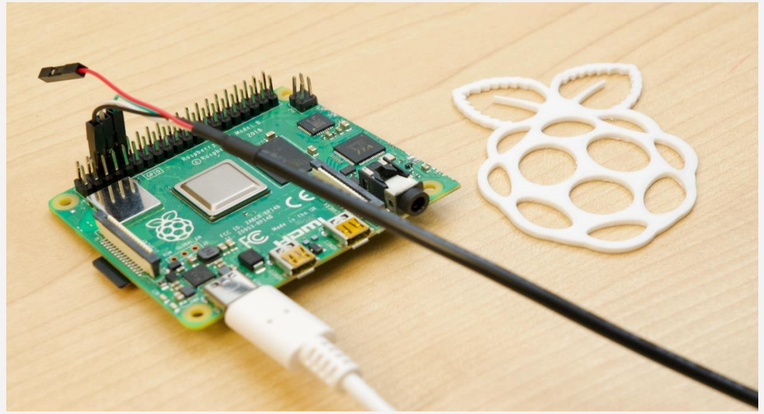
CVSS score: 7.6 (High Severity)

Boot loader accessible via hardware serial console port with no authentication allowed full access to device memory.

- Dump memory
- Extract & reverse engineer file system
- Identify sensitive data
- PWN!

Impact:

- Full device access (ability to set root password)
- Control of any device function (root can do everything)
- Full ability to interact with the physical world
- Access to local sensitive data
- Impersonate device to access cloud resources



```
U-Boot 2018.09 (Oct 04 2018 - 05:36:06 -0700)

DRAM:  128 MiB
RPI Zero (0x900093)
MMC:   sdhci@7e300000: 0
Loading Environment from FAT... *** Warning - bad CRC, using default environment

In:    serial
Out:   vidconsole
Err:   vidconsole
Net:   No ethernet found.
starting USB...
USB0:   scanning bus 0 for devices... 2 USB Device(s) found
        scanning usb for storage devices... 0 Storage Device(s) found
Hit any key to stop autoboot:  0
U-Boot>
```

Hacking Example - Findings

Vulnerability: Command Injection

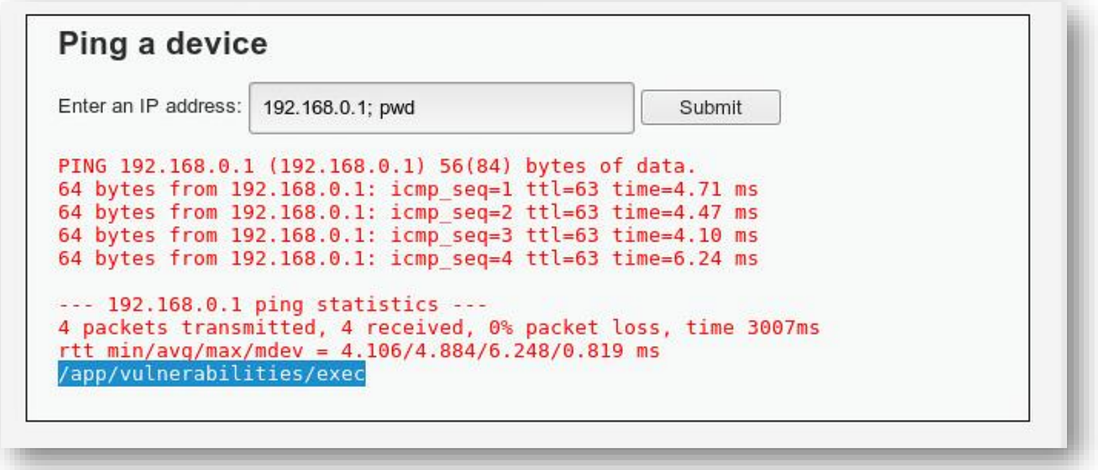
CVSS score: 9.0 (Critical Severity)

Administrative web interface (requires authenticated access)

- Test all fields for potential injection flaws
- Identify unexpected behavior
- Weaponize
- Exploit (e.g. set root password -> connect via SSH -> control)

Impact:

- **Remote (local network)** control of device function (root can do everything)
- **Remote** ability to interact with the physical world
- **Remote** access to local sensitive data
- Impersonate device to access cloud resources



Securing XIoT

XIoT Security – A Shared Responsibility

Manufacturer			Owner	
Practice	**Examples**		**Practice**	**Example**
Build secure by design products	Secure software development life cycle (SDLC) Penetration testing Software Bill of Materials (SBOM) Include recommended security features.	→	Procure secure devices	Purchasing standards, vendor and product evaluation, Manufacturer Disclosure Statement for Medical Device Security (MDS2)
Create user-facing cyber security guidance	IT Security Guide, Product Security Whitepapers	→	Secure deployment	Deploy according to manufacturer recommendations and industry best practices. Monitor and integrate with security tools.
Maintain product security	Track supply chain vulnerabilities, disclosure process, release products patches/updates, communicate	→	Maintain security	Create device inventory and establish visibility. Implement a patch/mitigation strategy (Tune in to vulnerability feeds)

A common conversation in XIoT security…

IT department: I have no idea what XIoT assets are out there!

Site Lead: I know exactly what's there, but I don't write it down.

Security department: (To site lead) Here's a platform where you can write it down.

Site Lead: I don't have time for that.

Security department: I guess we're on our own. ☹

Challenges with securing XIoT devices

Decentralization

- Every site has their own XIoT asset inventory

No enterprise security tool coverage

- No SCCM, Intune, AV, EDR, etc.

Network traffic looks different from IT

- Takes time to baseline, some normal traffic looks unusual

Some critical networks are unknown (or easily missed)

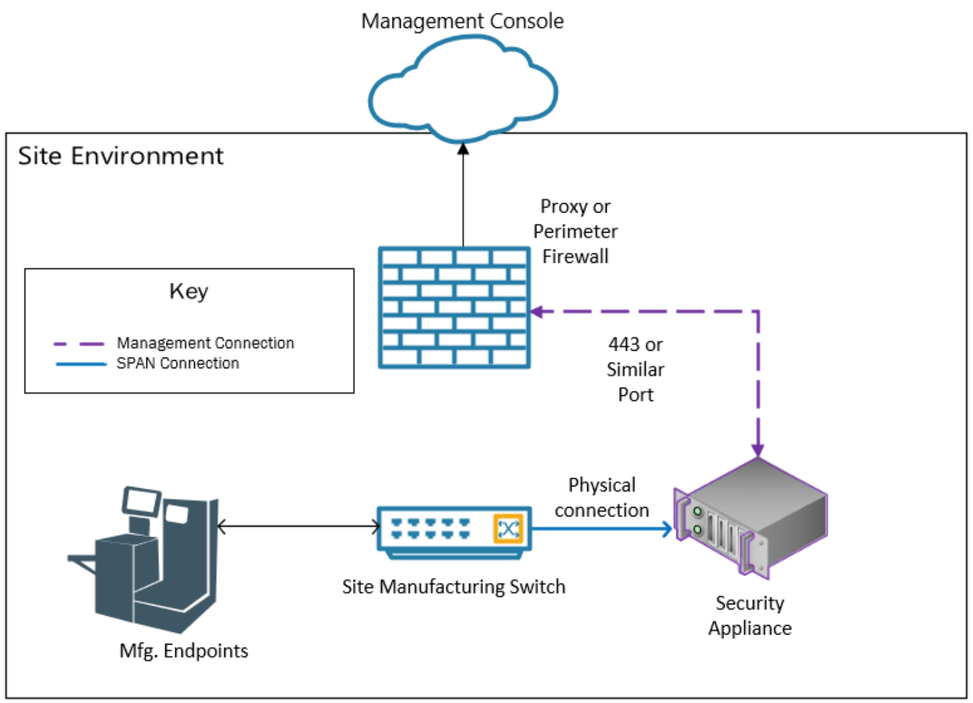
- After conversations with site personnel, the team will learn about different appliances or rooms that were previously unknown

No incentive to work on security issues

- Site IT folks do not have time devoted/budgeted for security

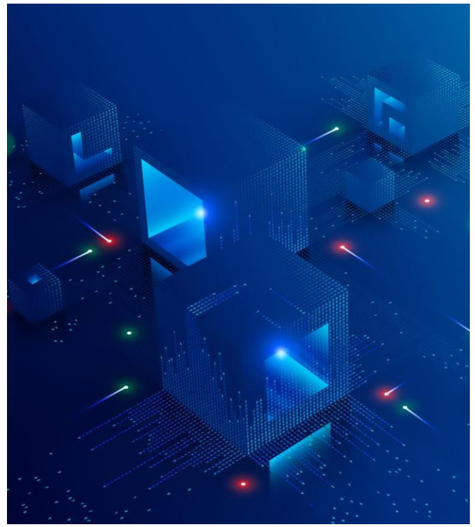
Defensive Tooling

- Lots of vendors moving into this space (lots of VC money)
- Common features:
  - Sensors on-prem, management console SaaS
  - Integrations with firewalls/security tools
  - Traffic analysis
  - OT, Healthcare, and XIoT device identification
  - Some vulnerability management
- Strengths:
  - Passive monitoring, no interruptions to XIoT devices
  - Quick time-to-value
- Weaknesses:
  - Hard to “master”
  - Deploying correctly takes *lots* of time and effort



Example of a deployment in a manufacturing environment

XIoT Defense Frameworks vs. Experience



New frameworks emerging everyday, here's some we looked at:

- NIST SP 1800-32A: Securing the Industrial Internet of Things
- Industry IoT Consortium Security Maturity Model and Security Framework
- IoT Security Institute smart cities & critical infrastructure framework

What the frameworks conclude:

1. Authentication and Access Control
2. Behavioral Monitoring
3. Log of Commands/Events
4. Protection of Data
5. Response Plan

VS.

Our conclusions from experience:

1. Build strong relationships with site personnel
2. Catalog XIoT devices on the network using a centralized tool
3. Log network traffic in a third-party platform
4. Test the response plan using TableTop Exercises (TTXs)
5. Segmentation

Q & A

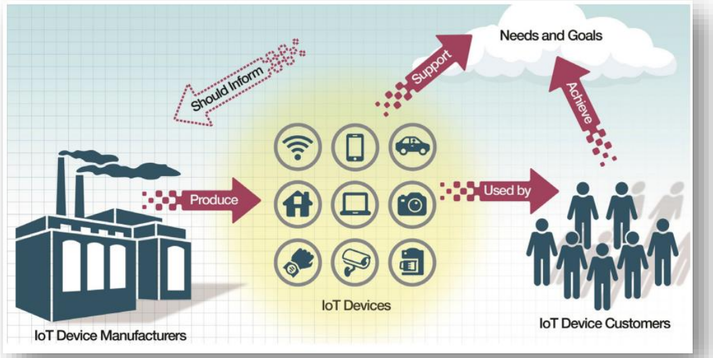
XIoT Security Resources

For Device Manufacturers

- NIST IR 8259 - Foundational Cybersecurity Activities for IoT Device Manufacturers
- ETSI EN 303 645 - V2.1.1 - CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements
- OWASP IoT Security Verification Standard (ISVS)

For Device Owners

- NISTIR 8228: Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risks now available.
- NIST.SP.800-82r3 – Guide to Operational Technology (OT) Security
  - Section 5.3.7 Additional Security Considerations for IIoT
- NIST.SP.1800-8 – Securing Wireless Infusion Pumps



Conclusions in Practice

Build strong relationships with site personnel
- No security control will be effective without a partnership

Log as much as possible in a third-party platform
- Expand collection of log sources

Access Control
- Site personnel do not want this, requires strong relationships

Build and test a response plan
- TTXs using IoT scenarios are a great place to start

Gain visibility into IoT devices on your network using a centralized tool
- Agents most likely not available for IIoT devices

CVSS Calculations

CVSS v3.1 Vector

AV:P/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) | Adjacent Network (AV:A) | Local (AV:L) | **Physical (AV:P)**

Attack Complexity (AC)*

Low (AC:L) | High (AC:H)

Privileges Required (PR)*

None (PR:N) | Low (PR:L) | High (PR:H)

User Interaction (UI)*

None (UI:N) | Required (UI:R)

Scope (S)*

Unchanged (S:U) | **Changed (S:C)**

Impact Metrics

Confidentiality Impact (C)*

None (C:N) | Low (C:L) | **High (C:H)**

Integrity Impact (I)*

None (I:N) | Low (I:L) | **High (I:H)**

Availability Impact (A)*

None (A:N) | Low (A:L) | **High (A:H)**

CVSS v3.1 Vector

AV:A/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) | **Adjacent Network (AV:A)** | Local (AV:L) | Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) | High (AC:H)

Privileges Required (PR)*

None (PR:N) | **Low (PR**

This metric describes the level of privileges an attacker must possess before successfully exploiting the vulnerability.

User Interaction (UI)*

None (UI:N) | Required

Scope (S)*

Unchanged (S:U) | **Changed (S:C)**

Impact Metrics

Confidentiality Impact (C)*

None (C:N) | Low (C:L) | **High (C:H)**

Integrity Impact (I)*

None (I:N) | Low (I:L) | **High (I:H)**

Availability Impact (A)*

None (A:N) | Low (A:L) | **High (A:H)**